GRC103 Advanced Cybersecurity Risk Quantification

Practical Lab 3A Advanced GRC Phishing Simulation & Quantitative Risk Analysis

Student Information	
Full Name	Khodani Netshifhefhe
Registration Number	C11/26/CGRCE/17580
Email Address	c11.cgrce2617580@icdfa.edu.ng
Submission Date	01 November 2026

PHASE 1: BASIC METRIC CALCULATIONS

Step 1: Calculate Fundamental Rates

Formula: Rate = (Number of Events / Number of Emails Sent) × 100*

Campaign	Email Open Rate	Click-Through Rate	Credential Submission Rate	Data Entry Rate
A	(82/100)×100 = 82%	(47/100)×100 = 47%	(18/100)×100 = 18%	(5/100)×100 = 5%
B	(200/250)×100 = 80%	(150/250)×100 = 60%	(75/250)×100 = 30%	(25/250)×100 = 10%
C	(72/80)×100 = 90%	(60/80)×100 = 75%	(12/80)×100 = 15%	(8/80)×100 = 10%

Step 2: Efficiency metrics

Open-to-click conversion rate

- Campaign A: (47/82)×100 = 57.3%
- Campaign B: (150/200)×100 = 75%
- Campaign C: (60/72)×100 = 83.3%

Post-click credential submission rate

- Campaign A: (18/47)×100 = 38.3%
- Campaign B: (75/150)×100 = 50%
- Campaign C: (12/60)×100 = 20%

Campaign B converts best after the click (50%). Campaign C gets the most opens and clicks, but many recipients drop out at the credential step.

Phase 2: Advanced Risk Quantification

Step 3: Organizational risk exposure (Campaign B)

- Credential rate: 75/250 = 30%
- Expected credentials stolen: 2,000 × 0.30 = 600 employees
- Expected breaches: 600 × 0.25 = 150 breaches

Step 4: Financial impact analysis

- Single loss expectancy (SLE): $4,350,000
- Annual rate of occurrence (ARO): 150
- ALE = $4,350,000 × 150 = $652,500,000

Step 5: Control effectiveness analysis

MFA

- Cost: $45 × 2,000 = $90,000
- Risk reduction: $652,500,000 × 0.999 = $651,847,500
- ROI: ($651,847,500 − $90,000) / $90,000 = 724,175%

Security training

- Cost: $50 × 2,000 = $100,000
- New click-through rate: 30% × (1 − 0.60) = 12%
- New credentials stolen: 2,000 × 0.12 = 240; new breaches: 240 × 0.25 = 60
- New ALE: $4,350,000 × 60 = $261,000,000
- Risk reduction: $652,500,000 − $261,000,000 = $391,500,000
- ROI: ($391,500,000 − $100,000) / $100,000 = 391,400%

Phase 3: Comprehensive Risk Assessment

Step 6: Risk assessment matrix

Exposure = (credential rate × 2,000) × 25% × $4,350,000

Campaign	Credential rate	Employees	Breaches (×25%)	Financial exposure	Risk	Priority	Action
A	18%	360	90	$391,500,000	MEDIUM-HIGH	3	Enhanced training

B	30%	600	150	$652,500,000	CRITICAL	1	Immediate MFA
C	15%	300	75	$326,250,000	HIGH	2	Executive training and MFA

Note on the lab figures:

The lab prints $156,600,000 for A and $104,400,000 for C. Those equal 36 and 24 breaches, which do not follow from the formula shown in the lab. The values above apply the formula consistently. Campaign C is ranked above A despite a lower credential rate because executives hold more privileged access, so each compromised account carries a higher potential impact.

Step 7: Statistical significance Analysis

Calculate Confidence Intervals (95% Confidence):

Formula: $p \pm 1.96 \times \sqrt{[p(1-p)/n]}$*

Campaign B (reference):

- p = 0.30, n = 250
- Margin of error = $1.96 \times \sqrt{(0.21/250)} = 1.96 \times 0.029 = 0.057$
- **True Range: 24.3% to 35.7%**

Campaign A:

- p = 0.18, n = 100.
- Margin of error = $1.96 \times \sqrt{[0.18 \times 0.82 / 100]} = 1.96 \times \sqrt{0.001476} = 1.96 \times 0.0384 =$ **0.0753**
- True rate range: **10.5% to 25.5%**

Interpretation: A's interval is wider because its sample is smaller (n = 100 vs 250). The two intervals overlap only slightly (24.3% to 25.5%), so Campaign B is very likely the more effective lure.

Phase 4: Executive Reporting

Executive briefing

To: Board of Directors, CISO, CFO

From: GRC Risk Analysis Team

Date: 3 November 2026

Subject: CRITICAL: Quantitative Phishing Risk Assessment & $652.5M Modeled Exposure

1. Executive summary

Our phishing simulations show a critical exposure. Campaign B ("IT Password Reset") achieved a 30% credential submission rate (95% CI: 24.3% to 35.7%). Extrapolated to 2,000 employees, this implies roughly 600 compromised accounts and about 150 breach events, a modeled annualized loss expectancy of $652.5M. Enterprise-wide MFA ($90,000) is the highest-return control, followed by targeted training ($100,000) and email filtering ($50,000). A $490,000 investment is projected to cut modeled exposure by about 90%.

2. Key quantitative findings

Risk metric	Value	Notes
Overall credential theft rate	24.4% (105 / 430)	Pooled across all three campaigns. The lab's 22.1% does not match the data.
Maximum campaign success rate	30% (Campaign B)	CRITICAL
Annualized loss expectancy	$652.5M	Worst-case, model-driven figure
MFA implementation ROI	724,175%	Assumes 99.9% effectiveness
Per-employee modeled risk	$326,250	$652.5M / 2,000

3. Proposed security investment portfolio

Control	Cost	Risk reduction	Net benefit	ROI	Priority
MFA implementation	$90,000	$651.8M	$651.76M	724,175%	1

Enhanced training	$100,000	$391.5M	$391.4M	391,400%	2
Email filtering	$50,000	$130.5M	$130.45M	260,900%	3

Email filtering ROI = ($130,500,000 − $50,000) / $50,000 = 2,609 = 260,900%

4. Strategic recommendations

Immediate actions (Q1)

- Implement MFA enterprise-wide: $90,000
- Launch a targeted phishing simulation program: $25,000
- Conduct emergency security awareness training: $100,000

Strategic initiatives (next fiscal year)

- Deploy an advanced email security gateway: $50,000
- Establish continuous security monitoring: $150,000
- Implement security behavior analytics: $75,000

5. Expected risk posture after controls (90% reduction)

Metric	Current	With controls	Reduction
Credential theft rate	24.4%	~ 2.4%	90%
Annual loss expectancy	$652.5M	~ $65.25M	90%
Total investment required		$490,000	
Total risk reduction		$587.25M (0.90 × $652.5M)	
Net financial benefit		$586.76M ($587.25M − $490,000)	

Bonus Challenge

$490,000 / $4,350,000 per breach = **0.11 breaches**.